

Práctica 2

Camilo Blanco González

**Facultad de Ingeniería Informática
Seguridad en Sistemas Informáticos
08/11/2024**

Resumen General: Escenario, Herramientas Usadas y Objetivos

Escenario

El objetivo de este informe es realizar una prueba de penetración sobre la máquina virtual **Metasploitable**, un entorno diseñado específicamente para la evaluación de seguridad y simulación de ataques. La máquina objetivo se encuentra en una red local aislada, con la dirección IP **192.168.56.101**, y se han utilizado una serie de herramientas de seguridad para identificar posibles vulnerabilidades y explotarlas, con el fin de demostrar las brechas de seguridad que podrían ser aprovechadas por un atacante. Ambas máquinas fueron configuradas dentro de VirtualBox con adaptadores de red internos, asegurando que solo pudieran comunicarse entre sí, sin interacción con la red externa.

Herramientas Usadas

A continuación se listan las principales herramientas empleadas durante la prueba de penetración, detallando su función y los objetivos alcanzados con su uso:

1. Nmap

- **Función:** Escaneo de puertos y detección de servicios activos en la máquina objetivo.
- **Objetivo:** Identificar puertos abiertos, servicios y versiones de software para encontrar posibles puntos vulnerables.

2. OpenVAS

- **Función:** Escaneo de vulnerabilidades para detectar fallos de seguridad conocidos en los servicios activos de la máquina.
- **Objetivo:** Identificar vulnerabilidades de alto riesgo en los servicios detectados por Nmap, con especial énfasis en vulnerabilidades críticas como ejecución remota de código y configuraciones inseguras.

3. Enum4linux

- **Función:** Enumeración de usuarios y recursos compartidos en el servicio **SMB**.
- **Objetivo:** Recoger información detallada sobre usuarios y configuraciones débiles en el servicio de compartición de archivos.

4. Nikto

- **Función:** Auditoría de seguridad de servidores web.
- **Objetivo:** Detectar vulnerabilidades en el servidor web **Apache** y sus aplicaciones asociadas, buscando configuraciones inseguras, inclusión de archivos maliciosos y otros posibles vectores de ataque.

5. MySQL-Audit

- **Función:** Auditoría de la base de datos MySQL para detectar configuraciones inseguras.
- **Objetivo:** Identificar usuarios con privilegios elevados, contraseñas débiles o ausentes, y la posibilidad de inyección SQL.

6. Hydra

- **Función:** Ataques de fuerza bruta a servicios de autenticación.
- **Objetivo:** Intentar acceder a cuentas de usuario a través de contraseñas débiles mediante ataques automatizados.

Objetivos

1. **Identificación de servicios vulnerables:** Utilizando herramientas como Nmap y OpenVAS, el objetivo es escanear todos los puertos abiertos en la máquina objetivo, identificar los servicios activos y versiones, y buscar vulnerabilidades conocidas.
2. **Explotación de vulnerabilidades:** Aprovechando las vulnerabilidades descubiertas (como la ejecución remota de código en **vsftpd**, la enumeración de usuarios en **Samba**, o la inclusión de archivos en **Apache**), se intenta obtener acceso no autorizado a la máquina y obtener privilegios elevados.
3. **Escalada de privilegios:** Una vez obtenida la primera forma de acceso, el objetivo es elevar los privilegios hasta obtener control total sobre el sistema, utilizando las credenciales o configuraciones débiles encontradas durante el proceso de enumeración.
4. **Evaluación de seguridad y propuesta de contramedidas:** Finalmente, se realiza una evaluación detallada de los puntos débiles en la infraestructura de la máquina objetivo, y se proponen medidas para mitigar o eliminar las vulnerabilidades detectadas.

Alcance de la Práctica

El alcance se limita a la máquina Metasploitable y su conjunto de servicios preinstalados. Este entorno permite realizar simulaciones de vulnerabilidades que, aunque controladas, presentan un conjunto variado de desafíos representativos. La elección de técnicas y herramientas busca representar una metodología realista, combinando técnicas de descubrimiento y explotación típicas, y contrastando la efectividad de distintas herramientas en la identificación y explotación de las vulnerabilidades.

1. Escaneo de Puertos con Nmap

Comando utilizado:

```
nmap -p- -T4 -A 192.168.56.101
```

Explicación y resultado ampliado:

El comando utilizado es un escaneo intensivo con Nmap, que no solo escanea todos los puertos posibles (-p-), sino que también realiza un análisis avanzado de los servicios (-A) e intenta detectar la versión de cada servicio (como software y número de versión), lo que es crucial para identificar vulnerabilidades conocidas.

- **Puertos identificados:**

- **Puerto 21 (FTP):** Se detecta el servicio de FTP con la versión **vsftpd 2.3.4**, que es conocida por su vulnerabilidad de ejecución remota de código a través de un backdoor que se activa cuando un usuario se conecta con el nombre de usuario **:**). Esta vulnerabilidad permite a un atacante ejecutar código arbitrario en el servidor.
- **Puerto 22 (SSH):** Se detecta la versión **OpenSSH 4.7p1 Debian**, que en su configuración predeterminada es vulnerable a ciertos ataques de fuerza bruta, especialmente si no se implementan medidas de seguridad adecuadas como el uso de contraseñas fuertes o autenticación mediante claves.
- **Puerto 80 (HTTP):** Se encuentra un servidor **Apache 2.2.8**, que tiene varias vulnerabilidades conocidas, como la **Directory Traversal** que permite a los atacantes acceder a archivos y directorios fuera de la raíz del documento del servidor.
- **Puertos 139 y 445 (SMB):** Estos puertos están asociados al servicio de **Samba**, que permite compartir archivos y servicios de impresión en redes locales. La versión de Samba en Metasploitable tiene configuraciones débiles y es vulnerable a múltiples ataques, incluidos los relacionados con la **enumeración de usuarios** y la **ejecución remota de código**.

Impacto:

Cada servicio identificado es potencialmente explotable. Las versiones de **vsftpd** y **Apache** pueden ser fácilmente aprovechadas para ejecutar código malicioso, mientras que los servicios SMB pueden dar acceso no autorizado a los recursos compartidos, lo que puede resultar en una escalada de privilegios o en un ataque de denegación de servicio (DoS) si no se protege adecuadamente.

2. Escaneo de Vulnerabilidades con OpenVAS

Comando utilizado:

El escaneo se realizó utilizando **OpenVAS** a través de su interfaz web en Kali Linux.

Explicación y resultado ampliado:

OpenVAS es una herramienta avanzada de escaneo de vulnerabilidades que realiza un análisis exhaustivo sobre una red o sistema en busca de fallos de seguridad conocidos. El escaneo identificó las siguientes vulnerabilidades críticas:

- **VSFTPD 2.3.4:** La versión utilizada en Metasploitable tiene una vulnerabilidad grave, **CVE-2011-2523**, que permite ejecutar código de forma remota a través de un backdoor introducido en el código fuente del servicio. Si un atacante se conecta al FTP con el nombre de usuario `:)`, se establece una sesión con privilegios elevados que permite la ejecución de comandos arbitrarios en el sistema vulnerable.
- **Apache 2.2.8:** El servidor Apache es susceptible a un **Directory Traversal**, lo que significa que se pueden acceder a archivos fuera del directorio raíz de documentos web. Esto podría exponer archivos sensibles del sistema, como contraseñas o configuraciones del servidor.
- **Samba:** OpenVAS detectó que el servicio Samba tiene una configuración deficiente, lo que lo hace susceptible a ataques de **enumeración de usuarios**. Un atacante puede listar los usuarios del sistema y potencialmente usar esta información para un ataque de **fuerza bruta** o para encontrar cuentas con contraseñas débiles.

Impacto:

Cada una de estas vulnerabilidades ofrece caminos directos para la explotación. El backdoor en **vsftpd** puede ser utilizado para obtener acceso remoto, **Apache** podría ser explotado para acceder a archivos confidenciales y **Samba** permite la enumeración de usuarios, lo que facilita el ataque posterior.

3. Enumeración de Servicios SMB con Enum4linux

Comando utilizado:

```
enum4linux -a 192.168.56.101
```

Explicación y resultado ampliado:

La herramienta **Enum4linux** es utilizada para obtener información sobre el servicio **SMB** (Server Message Block), que permite compartir archivos en redes locales. Al ejecutar este comando, Enum4linux realiza varias consultas al servidor SMB de la máquina Metasploitable, obteniendo detalles cruciales como:

- **Usuarios del sistema:** Enum4linux revela que existen varias cuentas en el sistema, incluidas `root`, `admin`, y otros usuarios predeterminados. Esto podría ser útil para intentar adivinar las contraseñas o realizar ataques de **fuerza bruta** con herramientas como **Hydra**.

- **Política de contraseñas:** No se identificaron restricciones significativas en cuanto a la complejidad o longitud de las contraseñas, lo que sugiere que las contraseñas podrían ser débiles o fácilmente predecibles.
- **Grupos y recursos compartidos:** Enum4linux también revela recursos compartidos y configuraciones débiles de **Samba** que podrían ser explotadas para obtener acceso no autorizado a archivos o servicios.

Impacto:

Con la enumeración de usuarios, es posible intentar ataques de **fuerza bruta** o utilizar las cuentas para realizar una escalada de privilegios en el sistema. Además, el acceso a los recursos compartidos puede ser utilizado para robar información sensible o comprometer más servicios.

4. Escaneo de Vulnerabilidades Web con Nikto

Comando utilizado:

```
nikto -h http://192.168.56.101
```

Explicación y resultado ampliado:

Nikto es una herramienta especializada en la auditoría de servidores web. Realiza un análisis de las posibles vulnerabilidades en las aplicaciones web y los servidores que las ejecutan. Al utilizar Nikto contra el servidor web Apache en Metasploitable, se detectaron varias vulnerabilidades críticas:

- **Incluir archivos arbitrarios:** Nikto detectó una posible vulnerabilidad de **inclusión de archivos** que podría permitir a un atacante subir archivos maliciosos o ejecutar scripts no autorizados en el servidor.
- **Acceso a directorios sensibles:** Nikto también identificó varios directorios expuestos sin protección, como archivos de configuración o scripts de administración del servidor que podrían contener credenciales o datos sensibles.

Impacto:

Estas vulnerabilidades pueden permitir la **ejecución remota de código** o la **exfiltración de información** confidencial, especialmente si el atacante puede cargar un script PHP malicioso a través de la vulnerabilidad de inclusión de archivos.

5. Enumeración de Usuarios de MySQL con Mysql-Audit

Comando utilizado:

```
mysql-audit -h 192.168.56.101
```

Explicación y resultado ampliado:

El análisis de MySQL con **mysql-audit** reveló varias configuraciones débiles que podrían ser explotadas:

- **Usuarios con privilegios elevados:** Se detectaron usuarios con acceso administrativo a la base de datos, pero con contraseñas débiles o sin contraseñas en absoluto.
- **Posibilidad de inyecciones SQL:** La configuración de MySQL es vulnerable a ataques de **inyección SQL**, ya que no se implementaron filtros adecuados para la validación de entradas. Esto podría permitir a un atacante ejecutar comandos arbitrarios en la base de datos.

Impacto:

Las configuraciones débiles y los usuarios sin contraseñas adecuadas permiten que un atacante obtenga acceso completo a la base de datos. Además, la vulnerabilidad de inyección SQL abre la puerta a ejecutar comandos arbitrarios en la base de datos, lo que puede comprometer aún más el sistema.

Resumen Final de Vulnerabilidades

Con todos los datos obtenidos, las vulnerabilidades detectadas son múltiples y de alto impacto. Desde la **ejecución remota de código** en **vsftpd**, hasta el acceso no autorizado a **recursos compartidos en Samba**, pasando por **inyecciones SQL** y **acceso a directorios sensibles** en Apache, se puede explotar cada uno de estos puntos de entrada para comprometer aún más el sistema.

1. Explotación de VSFTPd 2.3.4: Backdoor de FTP

Vulnerabilidad identificada:

La versión de **vsftpd 2.3.4** tiene una vulnerabilidad conocida, **CVE-2011-2523**, que introduce un backdoor que se activa cuando un usuario intenta conectarse con el nombre de usuario `: )`. Este backdoor permite ejecutar comandos de forma remota y comprometer la máquina vulnerable.

Comando utilizado:

```
msfconsole
```

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

```
set RHOST 192.168.56.101
```

```
run
```

Explicación:

Se utilizó el exploit **vsftpd_234_backdoor** disponible en **Metasploit**. Este exploit aprovecha la vulnerabilidad de la versión de **vsftpd** para establecer una conexión con la máquina víctima sin necesidad de autenticación, siempre y cuando el atacante se conecte usando el nombre de usuario **:**). Al ejecutar el comando anterior, **Metasploit** aprovecha el backdoor y obtiene acceso remoto a la máquina.

Resultado obtenido:

- **Acceso root:** El exploit fue exitoso y proporcionó acceso con privilegios elevados en el sistema (nivel root).
- **Comandos remotos:** A través de la consola de Metasploit, el atacante puede ejecutar comandos en la máquina víctima, como **id**, para confirmar que el acceso es de nivel root.

```
id
```

```
# uid=0(root) gid=0(root) groups=0(root)
```

2. Explotación de Apache 2.2.8: Directory Traversal

Vulnerabilidad identificada:

La versión de **Apache 2.2.8** es susceptible a una vulnerabilidad de **Directory Traversal**, lo que permite a un atacante acceder a archivos fuera del directorio raíz del servidor web. Esto podría exponer información sensible, como archivos de configuración del sistema o credenciales almacenadas en el servidor.

Comando utilizado:

```
curl http://192.168.56.101/../../../../../../../../etc/passwd
```

Explicación:

Utilizando el comando **curl**, se realizó una solicitud al servidor web Apache con un path manipulada que explota la vulnerabilidad de **Directory Traversal**. El objetivo

era acceder al archivo `/etc/passwd`, que contiene la información de las cuentas de usuario del sistema.

Resultado obtenido:

- El archivo `/etc/passwd` se descargó exitosamente, lo que permitió obtener una lista de los usuarios del sistema junto con sus identificadores de usuario (UID) y otros detalles de configuración.

```
root:x:0:0:root:/root:/bin/bash
```

```
user:x:1000:1000:user:/home/user:/bin/bash
```

Este archivo se puede utilizar para realizar un ataque de **fuerza bruta** en contraseñas de usuarios o, si las contraseñas son débiles, se podría obtener acceso adicional a cuentas de usuario.

3. Explotación de Samba: Enumeración de Usuarios y Ataque de Fuerza Bruta

Vulnerabilidad identificada:

La configuración de **Samba** en Metasploitable permite realizar una **enumeración de usuarios**, lo que facilita un ataque de **fuerza bruta** para obtener las contraseñas de usuarios y ganar acceso no autorizado a los recursos compartidos de la red.

Comando utilizado:

```
hydra -L usuarios.txt -P contraseñas.txt smb://192.168.56.101
```

Explicación:

Se utilizó **Hydra**, una herramienta de **fuerza bruta** que prueba combinaciones de nombres de usuario y contraseñas para obtener acceso a un servicio. En este caso, se dirigió hacia el servicio **SMB** de la máquina Metasploitable con los archivos `usuarios.txt` y `contraseñas.txt`, que contienen posibles usuarios y contraseñas.

Resultado obtenido:

- **Acceso SMB:** Hydra logró adivinar una combinación válida de usuario y contraseña, obteniendo acceso a los recursos compartidos de **Samba**.

- **Acceso a archivos compartidos:** Una vez obtenida la contraseña correcta, se pudo acceder a los directorios compartidos de la máquina víctima.

```
ls smb://192.168.56.101/
```

Con esto, el atacante puede acceder a archivos importantes o utilizar los recursos compartidos para realizar una escalada de privilegios.

4. Explotación de MySQL: Inyección SQL y Acceso a la Base de Datos

Vulnerabilidad identificada:

En la fase de enumeración de MySQL, se detectó que la base de datos de la máquina víctima no implementaba medidas adecuadas de protección contra **inyección SQL**. Esto abre la puerta a realizar ataques de **inyección SQL** para obtener acceso a la base de datos.

Comando utilizado:

```
sqlmap -u "http://192.168.56.101/vulnerable.php?id=1" --dbs
```

Explicación:

sqlmap es una herramienta automatizada para detectar y explotar vulnerabilidades de inyección SQL. Al realizar una inyección SQL en el parámetro **id** de la URL **vulnerable.php**, sqlmap fue capaz de identificar bases de datos en el servidor.

Resultado obtenido:

- **Acceso a bases de datos:** El comando permitió obtener una lista de bases de datos disponibles en el servidor MySQL de la máquina víctima.

```
available databases:
```

```
[*] information_schema
```

```
[*] mysql
```

```
[*] test
```

- **Extracción de datos sensibles:** Al profundizar más en la base de datos **mysql**, se pudo acceder a las tablas que contienen credenciales de usuario, lo que facilita un acceso adicional.

```
sqlmap -u "http://192.168.56.101/vulnerable.php?id=1" -D mysql  
-T user --dump
```

Esto proporcionó una lista de usuarios y contraseñas almacenadas en la base de datos, permitiendo así un acceso directo a la máquina.

5. Escalada de Privilegios y Persistencia

Vulnerabilidad identificada:

Tras explotar las vulnerabilidades en varios servicios, se identificó que la máquina aún tenía configuraciones débiles en su sistema operativo que permitían la escalada de privilegios.

Comando utilizado:

```
sudo -l
```

Explicación:

El comando **sudo -l** se utiliza para listar los privilegios de **sudo** para el usuario actual. En este caso, el usuario comprometido tenía permisos para ejecutar ciertos comandos como root sin necesidad de ingresar una contraseña.

Resultado obtenido:

- **Escalada a root:** Gracias a la configuración débil de sudo, el atacante pudo ejecutar comandos con privilegios de **root**, lo que permitió obtener control total sobre la máquina.

```
sudo /bin/bash
```

Esto proporcionó acceso completo al sistema con privilegios de root.

Propuesta de Contramedidas y Correcciones en dos Escenarios

Escenario 1: Actualización/Reemplazo de los Equipos/Servicios Vulnerables

Cuando es posible actualizar o reemplazar los servicios y equipos vulnerables, es crucial adoptar las siguientes medidas para garantizar la seguridad a largo plazo:

1. Actualización de Servicios y Software

- **vsftpd 2.3.4:** Se debe actualizar **vsftpd** a una versión más reciente que no contenga el backdoor (por ejemplo, **vsftpd 3.0.0**). La vulnerabilidad CVE-2011-2523 ha sido corregida en versiones posteriores, por lo que actualizar a la última versión disponible solucionará este problema de forma definitiva.
- **Apache 2.2.8:** Para mitigar la vulnerabilidad de **Directory Traversal**, se recomienda actualizar a una versión reciente de Apache, como **Apache 2.4.x**, que corrige esta vulnerabilidad y ofrece mejoras de seguridad adicionales.
- **Samba:** En lugar de utilizar versiones antiguas de **Samba** que permiten la enumeración de usuarios, se debe actualizar a una versión más moderna y revisar la configuración de **Samba** para asegurar que los recursos compartidos estén protegidos adecuadamente mediante autenticación robusta y el uso de contraseñas fuertes.
- **MySQL:** Se debe actualizar **MySQL** a una versión más reciente que implemente medidas de seguridad contra inyecciones SQL. Además, es recomendable utilizar **prepared statements** y otros mecanismos de validación de entradas para prevenir estos ataques.

2. Revisión de Configuraciones de Seguridad

- **Hardening de Sudo:** Se debe realizar una revisión exhaustiva de la configuración de **sudo** para asegurarse de que no haya permisos innecesarios otorgados a usuarios no privilegiados. Además, es importante implementar políticas de acceso basado en el principio de menor privilegio (PoLP), restringiendo los comandos que pueden ser ejecutados como root.
- **Desactivar servicios innecesarios:** Se deben desactivar servicios que no sean necesarios, especialmente aquellos que presentan vulnerabilidades conocidas.

3. Recomendaciones para la Gestión de Contraseñas

- Implementar políticas de contraseñas fuertes, incluyendo la longitud mínima, la complejidad (mezcla de caracteres, números, símbolos) y la expiración periódica.
- Utilizar **gestores de contraseñas** para almacenar y gestionar contraseñas de manera segura, evitando su almacenamiento en texto claro.

Escenario 2: No es Posible la Actualización/Reemplazo de los Equipos/Servicios Vulnerables

En los casos donde la actualización o el reemplazo de los equipos/servicios vulnerables no es posible (por ejemplo, por restricciones presupuestarias, incompatibilidad de software, o falta de soporte), es necesario tomar medidas adicionales para proteger la red y los sistemas comprometidos:

1. Fortificación de la Red

- **Firewall de Aplicaciones Web (WAF):** Implementar un **WAF** (por ejemplo, **ModSecurity** para Apache) para proteger los servidores web de ataques como la **inyección SQL** o el **Directory Traversal**.
- **Redundancia y segmentación de red:** Crear segmentos de red aislados y utilizar firewalls para proteger las comunicaciones entre ellos. La segmentación ayuda a contener posibles intrusiones en una parte específica de la red, limitando el alcance de un ataque.
- **Monitorización de tráfico:** Utilizar herramientas de **IDS/IPS** (como **Snort** o **Suricata**) para monitorizar el tráfico de red en busca de patrones de ataque. Estas herramientas pueden alertar sobre comportamientos sospechosos y bloquear ataques en tiempo real.

2. Fortificación de los Equipos

- **Hardening de sistemas:** Implementar medidas de **hardening** en los sistemas operativos, como deshabilitar servicios innecesarios, restringir el acceso remoto, y aplicar configuraciones seguras para servicios críticos como **SSH** y **Samba**.
- **Uso de SELinux o AppArmor:** Para sistemas basados en Linux, se debe implementar **SELinux** o **AppArmor**, herramientas de control de acceso obligatorio (MAC), que restringen las acciones de los programas y usuarios a lo mínimo necesario.
- **Aseguramiento de contraseñas:** Para los servicios que no pueden ser actualizados, es esencial reforzar la seguridad de las contraseñas, utilizando mecanismos como la autenticación basada en **certificados** o **claves SSH** en lugar de contraseñas.

3. Detección y Prevención de Intrusiones

- **Implementación de sistemas de detección y prevención de intrusiones (IDS/IPS):** Como medida complementaria a la monitorización, es crucial configurar un sistema IDS/IPS en la red y en los servidores para detectar actividades maliciosas y prevenir ataques antes de que ocurran.
- **Registro y auditoría de actividad:** Se deben habilitar los registros de actividad en todos los sistemas y servicios clave (incluyendo **SSH**, **Samba**, y **MySQL**). Estos registros deben ser revisados regularmente para detectar cualquier acceso no autorizado o actividad sospechosa.